

Relatório de Inteligência de Ameaça: Grupo STAC4749

Operação 'Spring Ring' e a implantação veloz do Ransomware Chaos via Microsoft Teams

Data: 10/09/2026 | Versão: 0.1

Gemini Notebook

Registros

DATA	AUTOR	VERSÃO	HISTÓRICO
10/09/2026	Thiago H	0.1	Criação do Documento

Sumário

1. Sumário Executivo
 - 1.1. Visão Geral da Ameaça
 - 1.2. Risco Atual para Organizações
 - 1.3. Medidas Prioritárias de Mitigação
2. Perfil do Ator de Ameaça
 - 2.1. Identidade, Origem e Afiliação
 - 2.2. Operação e Personas Utilizadas
3. Avaliação de Impacto e Vitimologia
 - 3.1. Análise Geográfica
 - 3.2. Segmentação de Setores Críticos
4. Análise Técnica da Cadeia de Ataque
 - 4.1. Engenharia Social e Acesso Inicial (Vishing no Teams)
 - 4.2. Abuso de Ferramentas de Suporte Remoto
 - 4.3. Implantação de Backdoor e Evasão de Defesa
 - 4.4. Persistência e Movimentação Lateral
 - 4.5. Execução Final de Criptografia (Ransomware Chaos)
5. Mapeamento MITRE ATT&CK
6. Análise de Infraestrutura e Comando e Controle
 - 6.1. Endereços de IP e Certificados TLS
 - 6.2. Domínio Falso de Suporte de TI
7. Estratégias de Mitigação e Ações Defensivas
8. Indicadores de Comprometimentos (IoCs)
9. Referências

Sumário Executivo

1.1 Visão Geral da Ameaça

O **STAC4749**, também rastreado sob a operação "**Spring Ring**", é um grupo de cibercrime financeiramente motivado que explora o recurso de comunicação externa do **Microsoft Teams** para realizar engenharia social avançada baseada em voz (*vishing*). Os atacantes se passam por técnicos de suporte corporativo de TI para induzir funcionários a concederem acesso remoto a endpoints organizacionais.

A campanha **não explora vulnerabilidades técnicas de dia zero (zero-day)** no Microsoft Teams, mas sim a confiança dos colaboradores e a falta de restrições em ferramentas legítimas de gerenciamento remoto. Entre fevereiro e junho de 2026, mais de 100 organizações foram comprometidas globalmente. O ciclo de vida do ataque, desde o contato telefônico inicial no Teams até a implantação total do Ransomware Chaos na rede, leva **menos de 17 horas**.



1.2 Risco Atual para Organizações

A ameaça representa risco **crítico** para empresas que mantêm a federação/comunicação externa habilitada por padrão no Microsoft Teams sem listas de permissão explícitas. A ausência de políticas estritas de Controle de Aplicativos (como AppLocker ou Windows Defender Application Control - WDAC) bloqueando softwares como **Quick Assist** e **RemSupp** permite a invasão direta da infraestrutura interna. O impacto é severo devido à inexistência de um decodificador público para o ransomware Chaos, resultando em perda irreversível de dados na ausência de backups isolados.

1.3 Medidas Prioritárias de Mitigação

1. Desativar a comunicação com contas externas ou restringi-la a domínios de parceiros homologados via Centro de Administração do Microsoft Teams.

2. Bloquear a execução do Microsoft Quick Assist (quickassist.exe) e da ferramenta RemSupp via AppLocker/WDAC em endpoints não autorizados.

3. Inserir os endereços IP de C2 identificados (94.140.114.192, 94.140.115.18, 94.140.115.129, 193.29.57.37) e os domínios maliciosos .top nas listas de negação do Firewall e Proxies.

Extra: Monitorar a criação de chaves maliciosas no registro sob

HKCU\Software\Microsoft\Windows\CurrentVersion\Run disfarçadas como componentes de áudio Realtek e WinAudio.



Perfil do Ator de Ameaça

2.1 Identidade, Origem e Afiliação

O cluster de ameaças **STAC4749** é monitorado pela comunidade de inteligência sob a designação **GOLD SOUVENIR**. Avaliações técnicas de alta confiança conectam os operadores do STAC4749 a **ex-integrantes** dos grupos de ransomware BlackSuit e Royal, os quais emergiram originalmente do sindicato criminoso **Conti**.

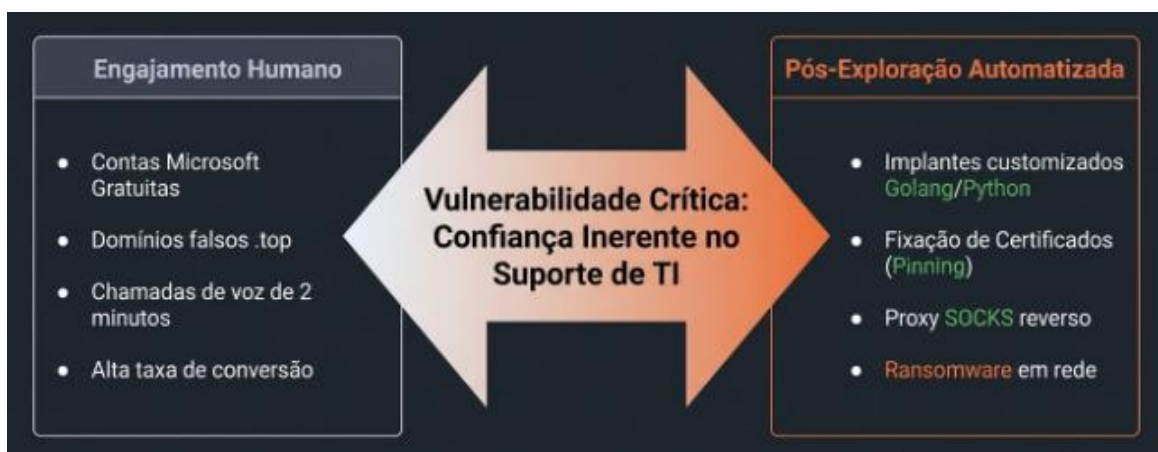
Análises forenses nos kits de ferramentas Golang e Python do STAC4749 revelaram uma sequência de comandos em cirílico digitada incorretamente (vshk em vez de dir), indicando um operador com layout de teclado **russo**. Hipóteses levantadas por analistas do setor sugerindo que o grupo seria uma operação de bandeira falsa associada ao estado iraniano (MuddyWater/COBALT ULSTER) foram descartadas por falta de evidências técnicas, confirmando a motivação estritamente financeira do grupo.

Identidade e Evolução da Ameaça



2.2 Operação e Personas Utilizadas

Para estabelecer contato persuasivo, os criminosos criam contas externas gratuitas na Microsoft utilizando nomes de exibição corporativos genéricos. Durante as abordagens, utilizam identidades falsas recorrentes, tais como **Anthony Brooks**, **Dylan Harper**, **Ethan Parker** e **Jason Mitchell**, afirmando pertencer à "equipe de suporte de TI"



Avaliação de Impacto e Vitimologia

3.1 Análise Geográfica

A distribuição geográfica dos alvos demonstra uma concentração quase total na **América do Norte (95% dos casos)**. O elevado índice no Canadá está associado ao amplo uso da plataforma Microsoft 365 combinado a políticas de acesso externo menos rígidas nas empresas do país

- **Canadá:** 50% das vítimas
- **Estados Unidos:** 45% das vítimas
- **Outras Regiões (Austrália, Índia):** 5% das vítimas

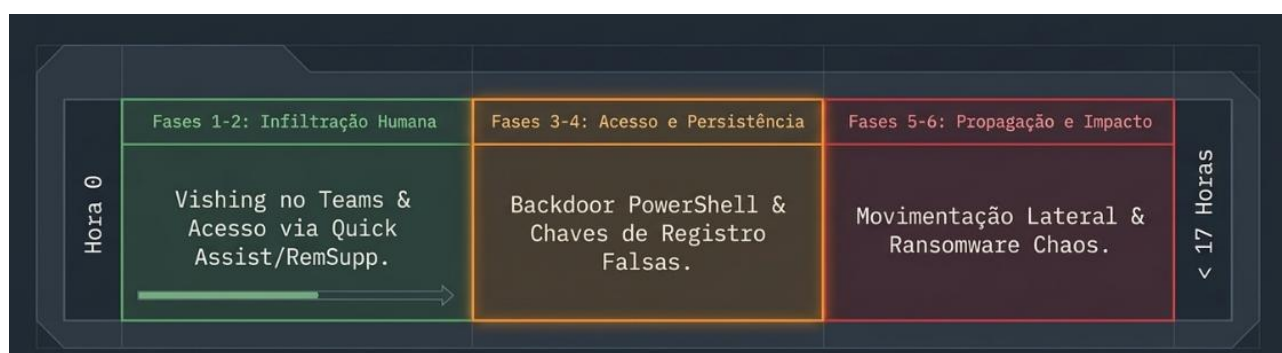
3.2 Segmentação de Setores Críticos

O grupo foca propositalmente em setores onde os colaboradores trabalham sob alta demanda operacional e possuem forte inclinação a cooperar com solicitações telefônicas do suporte técnico.

Setor Econômico	Percentual de Comprometimento
Serviços Profissionais	20%
Indústria de Transformação / Manufatura	17%
Energia e Serviços Públicos	12%
Construção e Engenharia	12%
Saúde e Outros Setores	39%

Análise Técnica de Cadeia de Ataque

A cadeia de ataque do STAC4749 é altamente padronizada e dividida em **6 fases consecutivas**:



4.1 Engenharia Social e Acesso Inicial (Vishing no Teams)

Os atacantes disparam chamadas de áudio e mensagens no Microsoft Teams a partir de domínios maliciosos externos como securityupdate.top, scan-security.top, system-connect.top, corp-connect.top e supportsoft.top.

As chamadas duram entre 90 segundos e 20 minutos, com média de **2 a 2,5 minutos**. O interlocutor alega a necessidade de aplicar uma atualização urgente de segurança no computador

4.3 Abuso de Ferramentas de Suporte Remoto

Com o controle da tela, o invasor abre o PowerShell e executa comandos para baixar o artefato de primeiro estágio diretamente no diretório %AppData% da vítima.

Os binários utilizam nomenclaturas de palavra única como confirm.exe, shield.exe, graph.exe, ou padrões aleatórios como sekv<10-dígitos>.exe, helper<10-dígitos>.exe e 74fs<10-dígitos>.exe. O malware utiliza ofuscação PyArmor e binários em Golang compilados com *certificate pinning* (fixando os certificados loop-CA, connectify-CA e james-bond-CA) para impedir que interceptadores de tráfego inspecionem a comunicação C2.

4.4 Persistência e Movimentação Lateral

O implantador cria chaves de inicialização em

HKCU\Software\Microsoft\Windows\CurrentVersion\Run disfarçadas como drivers de som legítimos, sob as entradas "Realtek HD Audio", "Realtek Audio UHD" e "WinAudio life2".

O atacante injeta o binário sc5.exe, um proxy SOCKS reverso capaz de gerenciar até 1.000 conexões simultâneas via domínio legio[.]name. Para garantir redundância de acesso, instalam silenciosamente o **DWAgent** e o **AnyDesk**, além de alterar o msconfig para habilitar o serviço RDP na máquina.

4.5 Execução Final de Criptografia (Ransomware Chaos)

Através da movimentação lateral obtida via RDP e ferramentas RMM, o ransomware **Chaos** é distribuído em massa em múltiplos endpoints. Arquivos corporativos são criptografados simultaneamente e notas de resgate rotuladas como readme.chaos.txt são depositadas nas pastas

Mapeamento MITRE ATT&CK

Abaixo encontra-se a matriz de táticas, técnicas e procedimentos (TTPs) alinhadas ao framework MITRE ATT&CK

Tática MITRE ATT&CK	ID da Técnica	Descrição da Técnica no Contexto do STAC4749
Initial Access	T1566.002	Phishing via serviço de voz (<i>vishing</i>) no Microsoft Teams.
Execution	T1059.001	Uso do PowerShell para download de scripts e payloads de primeiro estágio.
Persistence	T1547.001	Modificação de chaves de Run no Registro (HKCU\...\Run) disfarçadas de drivers.
Defense Evasion	T1140	Desofuscação de arquivos implantados criptografados via PyArmor.
Defense Evasion	T1036	<i>Masquerading</i> : Nomes de binários e chaves imitando componentes Realtek/WinAudio.
Command and Control	T1071.001	Protocolo C2 via gRPC/HTTPS na porta 443 com certificados CA customizados.
Command and Control	T1090.004	Uso de proxy SOCKS reverso (sc5.exe) via canal de borda.
Command and Control	T1219	Abuso de softwares legítimos de suporte remoto (Quick Assist, RemSupp, AnyDesk, DWAgent).
Impact	T1486	Criptografia de dados de ativos pelo ransomware Chaos.

6.1 Endereços IP e Certificados TLS

O grupo STAC4749 utiliza endereços IP fixos operando na porta 443 (HTTPS/gRPC) em vez de C2 baseado em DGA dinâmico. Os binários em Golang possuem certificados TLS embutidos gerados internamente com nomes comuns específicos.

- **IP C2 Primário:** 94.140.114.192 (Porta 443)
- **IP C2 Secundário:** 94.140.115.18 (Porta 443)
- **IP C2 Terciário:** 94.140.115.129 (Porta 443)
- **IP C2 do Implante Golang:** 193.29.57.37 (Certificado TLS com CN=james-bond-CA)

6.2 Domínios Falsos de Suporte de TI

Os atacantes registram domínios com o TLD .top simulando portais de atualização de TI

- securityupdate.top
- scan-security.top
- system-connect.top
- corp-connect.top
- supportsoft.top
- atualizacaodeseguranca.top

Estratégia de Mitigação e Ações Defensivas

7.1 Controles Administrativos e de Configuração do M365

1. Acesse o Centro de Administração do Microsoft Teams em *Acesso Externo*, desative a opção global e adicione apenas os domínios de parceiros comerciais confiáveis à lista de permissões.
2. Criar regras de bloqueio de execução para o Microsoft Quick Assist (C:\Windows\System32\quickassist.exe) e impedir a execução de binários do RemSupp e DWAgent em estações de trabalho não pertencentes à equipe de TI.

7.2

1. Adicionar os 4 IPs do C2 e os domínios com final .top à lista de bloqueio no resolvedor de DNS e no Firewall de Perímetro.
2. Configurar alertas no EDR/SIEM para identificar a criação de novas subchaves no caminho HKCU\Software\Microsoft\Windows\CurrentVersion\Run contendo termos como "Realtek" ou "WinAudio" apontando para caminhos sob %AppData%.
3. Validar periodicamente backups offline e isolados fisicamente (*air-gapped*), garantindo tempo de recuperação inferior à janela operacional de 17 horas do grupo.

Indicadores de Comprometimento (IoCs)

Tipo de Artefato	Indicador / Hash / Domínio	Detalhes / Contexto Operacional
Endereço IP (C2)	94.140.114.192	C2 primário dos implantes Golang via HTTPS (443).
Endereço IP (C2)	94.140.115.18	C2 secundário para redundância do grupo.
Endereço IP (C2)	94.140.115.129	C2 terciário de comunicação de implantes.
Endereço IP (C2)	193.29.57.37	C2 identificado pelo certificado TLS CN=james-bond-CA.
Domínio Falso de TI	securityupdate.top	Domínio malicioso usado para contato inicial e payloads.
Domínio Falso de TI	scan-security.top	Domínio usado em contatos falsos do Teams.
Domínio Falso de TI	system-connect.top	Infraestrutura de suporte falso.
Domínio Falso de TI	corp-connect.top	Domínio simulando conectividade corporativa.
Domínio Falso de TI	supportsoft.top	Domínio simulando software de suporte de TI.
Proxy C2	legio[.]name	Domínio de canal reverso do proxy SOCKS sc5.exe.
Chave de Registro	HKCU\...\Run\Realtek HD Audio	Entrada de persistência disfarçada apontando para AppData.
Chave de Registro	HKCU\...\Run\WinAudio life2	Entrada alternativa de persistência disfarçada.
Nota de Resgate	readme.chaos.txt	Arquivo gerado em pastas criptografadas pelo ransomware Chaos.

9.1 Referências:

Sophos X-Ops: [Sophos: Chaos in Teams vishing](#)

CyberSecurity Dive: [STAC4749 Chaos IOCs CSV](#)

Cyber Security Intelligence: [Teams Vishing Leads to Chaos Ransomware Attacks](#)

SophosLabs GitHub Repository (IoCs): [STAC4749 Chaos IOCs CSV](#)

Socura Threat Alerts: [Weaponisation of Microsoft Teams for IT Support Vishing](#)

BleepingComputer: [Microsoft Teams Vishing Attacks Lead to Chaos Ransomware](#)